

Access Control Policy

Identity lifecycle, least privilege, and access reviews (PR.AA)

Document ID: BVT-POL-032

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose, Scope, and Authority

This policy is part of the BVTech Written Information Security Program, aligned to the NIST Cybersecurity Framework (CSF) 2.0. It applies to all BVTech LLC personnel, contractors, systems, and, where adopted by a client, the client's covered environment. The Managing Partner (or designated security officer) owns this policy, reviews it at least annually, and approves exceptions in writing. Violations may result in disciplinary action up to termination of employment or contract.

Exception process: submit written request describing the business need, compensating controls, and duration. Exceptions expire after 12 months unless renewed. NIST CSF 2.0 references shown per section (GV, ID, PR, DE, RS, RC).

Account Lifecycle

- 1 Provisioning: accounts are created only upon written request from an authorized contact, with role-based permissions from documented templates.
- 2 Modification: privilege changes require the same authorization as creation; temporary elevations expire automatically or are removed within 24 hours of task completion.
- 3 Termination: access is disabled within 4 business hours of notified separation (same-hour for hostile separations), including SSO, email, VPN, SaaS, and physical access; sessions and tokens are revoked.
- 4 Review: all privileged accounts are reviewed quarterly; all user access reviewed semi-annually; stale accounts (no login 45 days) are investigated and disabled.

Privileged Access

- Separate admin accounts from daily-driver accounts; admin accounts have no mailbox where feasible.
- MFA is mandatory on all privileged access without exception.
- Vendor/third-party admin access is time-bound, logged, and uses named accounts — never shared credentials.
- Break-glass accounts are sealed, excluded from conditional access lockout scenarios, monitored for any use, and rotated after each use.

Authorization Standards

- Least privilege by default; deny-by-default network and share permissions.
- Segregation of duties for payments, code deployment to client systems, and backup deletion.
- Service accounts: documented owner, no interactive login where possible, credentials vaulted and rotated at least annually.